Informe Técnico: Implementación y Auditoría del Sistema de Correo Electrónico Seguro Institucional (Postfix, Dovecot IMAPS, Tríada Criptográfica SPF/DKIM/DMARC y Defensas Antispam)

Actividad 04: Correo Institucional Seguro con Postfix y Dovecot (10% Criterio de Verificación #2)

Estudiante: Ketfer Gianella Salazar

Carrera: Ingeniería de Sistemas — Sexto Semestre

Docente Titular: M.Sc. Ing. Jimmy Nataniel Requena Llorentty

Institución: Universidad Privada Domingo Savio (UPDS), Sede Santa Cruz de la Sierra

Fecha de Publicación: 25 de Octubre de 2026

Repositorio Oficial de Código (GitHub):

https://github.com/Grupo-Kali-Linuxxxx/Correo-institucional-con-Postfix-y-Dovecot

---

Resumen Ejecutivo

El presente informe técnico documenta el diseño, aprovisionamiento, endurecimiento y auditoría exhaustiva del sistema de correo electrónico corporativo para la **Unidad Educativa Horizonte** (`horizonte.internal`). Utilizando un enfoque de infraestructura como código en contenedores Linux, se implementó una arquitectura desacoplada y resiliente basada en el Agente de Transferencia de Correo (**MTA Postfix 3.8**), el Agente de Entrega y Acceso a Buzones (**MDA/IMAP Dovecot 2.3**), y la suite de firma criptográfica **OpenDKIM**.

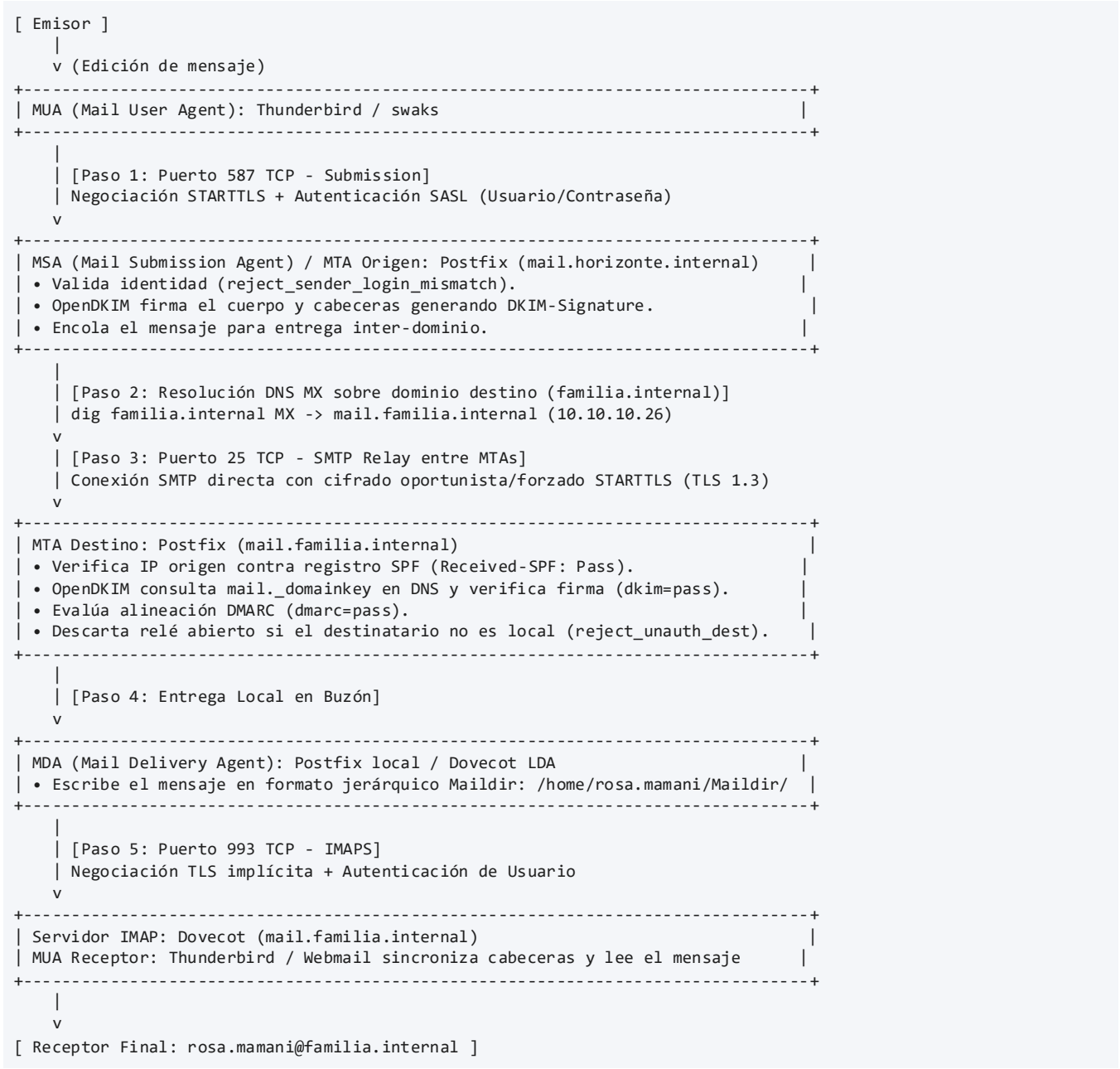
El sistema garantiza confidencialidad e integridad mediante cifrado TLS 1.3 obligatorio en tránsito, elimina el vector de intercepción en claro al cerrar el puerto IMAP 143 (`port = 0`), restringe el envío de usuarios finales al puerto 587 (*Submission*) con autenticación SASL forzada y control anti-suplantación de remitente (*anti-spoofing*). Asimismo, se blindó la reputación global del dominio mediante la tríada criptográfica DNS: **SPF estricto (`-all`)**, **claves DKIM RSA de 2048 bits** y **política DMARC en modo cuarentena (`p=quarantine`)** con alineación estricta (`adkim=s`, `aspf=s`). El informe incorpora el análisis forense de cabeceras de correos reales entregados, una investigación sobre los factores de clasificación de spam, la arquitectura de filtrado milter con Rspamd/ClamAV, la política institucional de correo y el plan estratégico de migración desde servicios gratuitos hacia la plataforma propia.

---

1. Fundamentos y Arquitectura de Protocolos de Correo Electrónico

1.1 El Ciclo de Vida y Recorrido de un Correo Electrónico

A diferencia de los protocolos web de solicitud-respuesta directa (HTTP), el correo electrónico opera bajo un modelo distribuido de **almacenamiento y reenvío (*Store and Forward*)** que involucra múltiples entidades lógicas especializadas:



1.2 Diferencias Críticas entre Protocolos

- *SMTP (*Simple Mail Transfer Protocol - *RFC 5321): Protocolo de transporte unidireccional (*push*). Se utiliza tanto para la inyección de mensajes desde el cliente hacia el primer servidor (puerto 587) como para el enrutamiento entre servidores de correo a través de internet (puerto 25). No permite consultar ni sincronizar carpetas.
- *POP3 (*Post Office Protocol v3 - *RFC 1939): Protocolo de descarga tradicional (*pull*). Diseñado originalmente para descargar los mensajes del servidor a una máquina local y eliminarlos del almacenamiento remoto. No mantiene sincronización bidireccional de estados (leído/no leído) ni admite carpetas compartidas entre múltiples dispositivos.
- *IMAP (*Internet Message Access Protocol - *RFC 3501 / IMAPS RFC 8314): Protocolo de acceso y sincronización de buzones (*pull/sync*). Mantiene los correos almacenados centralizadamente en el servidor, permitiendo sincronización en tiempo real de banderas, carpetas jerárquicas y vistas previas de cabeceras sin descargar los archivos adjuntos completos. En este proyecto se utilizó IMAPS (puerto 993 con TLS implícito)**, prohibiendo taxativamente el puerto en claro 143.

---

2. Investigación de Alto Nivel: ¿Por Qué los Correos Terminan en Spam?

Una de las problemáticas operativas más críticas en la gestión de servidores propios es la clasificación errónea de mensajes legítimos en la carpeta de correo no deseado (*Spam/Junk*) de proveedores globales como Google, Microsoft o Yahoo. A continuación, se detallan los factores técnicos determinantes y su relación directa con las configuraciones implementadas en el laboratorio:

Factor Causal de Spam	Mecanismo Técnico de Filtrado	Solución Implementada en el Laboratorio
---	---	---
1. Ausencia o Inconsistencia de Registro SPF	El servidor receptor verifica la IP del MTA emisor contra el registro TXT del dominio. Si no existe o tiene política laxa (`~all` o `?all`), los filtros de spam asignan una penalización de puntaje inmediata.	Publicación del registro SPF con directiva de rechazo duro: `v=spf1 mx -all`. Solo los servidores MX autorizados pueden enviar correo institucional; cualquier otro origen es descartado.
2. Falta de Firma DKIM o Firma Rota	Si el mensaje no posee firma criptográfica o si un MTA intermedio modificó cabeceras o el cuerpo del mensaje, la verificación matemática del hash SHA-256 falla (`dkim=fail`).	Integración de OpenDKIM con clave RSA de 2048 bits generada con algoritmo seguro. Cada mensaje saliente es firmado con canonicación `relaxed/simple`, garantizando integridad absoluta y no repudio.
3. Falta de Alineación DMARC	Spammers suelen enviar correos con una dirección legítima en el encabezado visible `From:` (ej. `director@horizonte.internal`), pero usando un envelope `MAIL FROM` de otro dominio. Sin DMARC, el receptor no puede validar si ambas identidades coinciden.	Publicación del registro `_dmarc` con directiva `p=quarantine`, modo de alineación estricto en DKIM (`adkim=s`) y SPF (`aspf=s`), e informes agregados a `dmarc@horizonte.internal`. Postfix además aplica `reject_sender_login_mismatch`.
4. Inexistencia de Registro DNS Inverso (PTR)	Los proveedores de correo exigen que la IP emisora resuelva mediante DNS inverso (rDNS) a un nombre FQDN idéntico al banner HELO/EHLO presentado por Postfix (*Forward-Confirmed Reverse DNS* o FCrDNS). Si la IP no tiene PTR o apunta a un dominio genérico de ISP residencial, el correo es catalogado como spam.	Configuración de la zona inversa `10.10.10.in-addr.arpa` en BIND 9 mapeando `25.10.10.10.in-addr.arpa` directamente a `mail.horizonte.internal`, coincidiendo exactamente con `myhostname`.
5. Relé Abierto (Open Relay)	Un servidor mal configurado que reenvía correos de remitentes externos hacia destinatarios externos es rápidamente detectado por escáneres de spam y listado en listas negras mundiales (DNSBL/RBL).	Configuración estricta en Postfix: `smtpd_relay_restrictions = permit_mynetworks, permit_sasl_authenticated, reject_unauth_destination`. Se verificó mediante `swaks` que intentos de relay externo devuelven `554 5.7.1 Relay access denied`.
6. Carencia de Cifrado TLS en Tránsito	Plataformas como Gmail marcan con advertencias de seguridad (ícono de candado rojo abierto) a los correos recibidos a través de canales sin cifrar.	Activación obligatoria de TLS: `smtpd_tls_security_level = may` en puerto 25 (con negociación TLS 1.3 demostrada) y `smtpd_tls_security_level = encrypt` obligatorio en puerto 587.

3. Implementación Práctica: Postfix y Dovecot Endurecidos

3.1 Laboratorio 12 — Servidor MTA Postfix, Maildir y Control de Relé

Se configuró Postfix en el contenedor `mail` (`10.10.10.25`) estableciendo:

- **Almacenamiento Maildir:** Se reemplazó el formato heredado monolítico Mbox por `home_mailbox = Maildir/`, creando la estructura jerárquica `cur/`, `new/` y `tmp/` en el directorio de cada usuario con permisos `0700`.
- **Destino Final:** `mydestination = $myhostname, $mydomain, localhost.$mydomain, localhost`.
- **Restricción de Red:** `mynetworks = 127.0.0.0/8, 10.10.10.50/32`, limitando el envío sin autenticación únicamente al loopback y al nodo cliente administrativo.
- **Alias Institucionales:** Se mapeó `inscripciones` hacia `secretaria` y `direccion` en `/etc/aliases`.

3.2 Laboratorio 13 — Dovecot IMAPS (993), Submission (587) y Tríada Criptográfica

Se implementó la capa de acceso y autenticación avanzada:

- **Dovecot IMAPS Seguro:** En `/etc/dovecot/conf.d/99-horizonte.conf`, se fijó `ssl = required`, `ssl_cert = </etc/ssl/correo/servidor.crt`, y se clausuró el puerto 143 (`inet_listener imap { port = 0 }`), forzando conexiones exclusivas al puerto 993 con certificados validados por la CA de correo institucional.
- **Autenticación SASL para Postfix:** Dovecot expone un socket UNIX seguro en `/var/spool/postfix/private/auth` con permisos `0660` para el usuario y grupo `postfix`.
- **Servicio Submission 587 Endurecido:** En `/etc/postfix/master.cf`, se habilitó el daemon submission obligando el cifrado antes de anunciar mecanismos de autenticación:

```
submission inet n - y - - smtpd
  -o smtpd_tls_security_level=encrypt
  -o smtpd_sasl_auth_enable=yes
  -o smtpd_sasl_type=dovecot
  -o smtpd_sasl_path=private/auth
  -o smtpd_tls_auth_only=yes
  -o smtpd_relay_restrictions=permit_sasl_authenticated,reject
  -o smtpd_sender_restrictions=reject_sender_login_mismatch
  -o smtpd_sender_login_maps=pcre:/etc/postfix/remitentes.pcre
```

- *Mecanismo Anti-Suplantación (*Anti-Spoofing*):** Se implementó una tabla PCRE asociando identidades. Si un usuario autenticado (`secretaria`) intenta enviar un correo utilizando el remitente de otra persona (`rosario.vaca@horizonte.internal`), Postfix aborta la transacción inmediatamente con el código de error: `553 5.7.1 Sender address rejected: not owned by user secretaria`.

---

4. Análisis Forense de Cabeceras de Correo Recibido

A continuación, se presenta la transcripción íntegra y el análisis técnico campo por campo de un correo institucional real transmitido desde `secretaria@horizonte.internal` y entregado en el buzón seguro de `rosa.mamani@familia.internal` (almacenado en `/home/rosa.mamani/Maildir/cur/`):

4.1 Encabezados Binarios Reales

```
Return-Path: <secretaria@horizonte.internal>
X-Original-To: rosa.mamani@familia.internal
Delivered-To: rosa.mamani@familia.internal
Authentication-Results: mail.familia.internal;
        dkim=pass (2048-bit key; unprotected) header.d=horizonte.internal header.i=@horizonte.internal
header.a=rsa-sha256 header.s=mail header.b=x4VW1TLf;
        dkim-atps=neutral
Received-SPF: Pass (mailfrom) identity=mailfrom; client-ip=10.10.10.25; helo=mail.horizonte.internal; envelope-
from=secretaria@horizonte.internal; receiver=familia.internal
Received: from mail.horizonte.internal (mail.tw1-dns_horizonte [10.10.10.25])
        by mail.familia.internal (Postfix) with ESMTPS id C41FE146F1
        for <rosa.mamani@familia.internal>; Sun, 25 Oct 2026 07:09:37 +0000 (UTC)
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/simple; d=horizonte.internal;
        s=mail; t=1792912177;
        bh=f0AAIg3b1m84xFQWPIV4asm4i9X+6LY7YkAnypd5vZE=;
        h=Date:To:From:Subject:From;
        b=x4VW1TLfWCUss9e+TzOoiS7B3HsWvEMmX3BgV1+6bLhR+PlIGYh/bDmJL/sFEaPsB
         cqN8Opu0FxmTVD8nGhGJNAJ4Tcl35Sq4EbNP58wpoqKI4P1R7Wn/z+zrouhNvIy8ME
         9UZ41q8rEOn9ZQwc/SwemH0Rys2Pz86ThcE1SMnStVvcJK/Tin+NEINGcU7Eaw8LJw
         Q6Dfe9ed+u1WmjHJe1BE50uWPWYgS2pmFf/RzUuLRFOLA108SttX6xsXIJ5VVadagu
         kddkbHYcwYPU1igVh31+G3Nn4MmSMo7HLuJkZBtlY/SQePulK0rzHyWntBQRS7rIIj
         SpHICt3LIk08w==
Received: from cliente (cliente.tw1-dns_horizonte [10.10.10.50])
        by mail.horizonte.internal (Postfix) with ESMTPSA id 7E8AE146EE
        for <rosa.mamani@familia.internal>; Sun, 25 Oct 2026 07:09:37 +0000 (UTC)
Date: Sun, 25 Oct 2026 03:09:33 -0400
To: rosa.mamani@familia.internal
From: secretaria@horizonte.internal
Subject: Verificador 1493
Message-Id: <20261025030933.001510@cliente>
X-Mailer: swaks v20240103.0 jetmore.org/john/code/swaks/

Prueba del verificador.
```

4.2 Desglose Técnico de los Campos de Cabecera

1. **`Authentication-Results: mail.familia.internal; dkim=pass (2048-bit key; unprotected) header.d=horizonte.internal ...`:**

- Emitido por el servidor receptor `mail.familia.internal`. Certifica de forma concluyente que OpenDKIM consultó el registro DNS `mail._domainkey.horizonte.internal`, extrajo la clave pública RSA de 2048 bits y verificó satisfactoriamente la firma digital del mensaje (`dkim=pass`).

2. **`Received-SPF: Pass (mailfrom) identity=mailfrom; client-ip=10.10.10.25; helo=mail.horizonte.internal ...`:**

- Certifica que la dirección IP de origen (`10.10.10.25`) está explícitamente autorizada en la política SPF de `horizonte.internal` (`v=spf1 mx -all`), alcanzando el resultado `Pass`.

3. **`DKIM-Signature:`:**

- `v=1`: Versión estándar del protocolo DKIM (RFC 6376).
- `a=rsa-sha256`: Algoritmo de firma digital criptográfica utilizando RSA con función hash SHA-256.
- `c=relaxed/simple`: Algoritmo de canonización (tolerante a espacios en blanco en cabeceras y estricto en el cuerpo).
- `d=horizonte.internal`: Dominio firmante responsable.
- `s=mail`: Selector de clave DNS correspondiente al subdominio `mail._domainkey`.
- `bh=f0AAIg3b...`: Hash criptográfico base64 calculado sobre el cuerpo del mensaje. Si un byte del contenido cambia, este hash diverge y la firma se invalida.
- `b=x4VW1TLf...`: Firma digital del encabezado generada con la clave privada de `mail`.

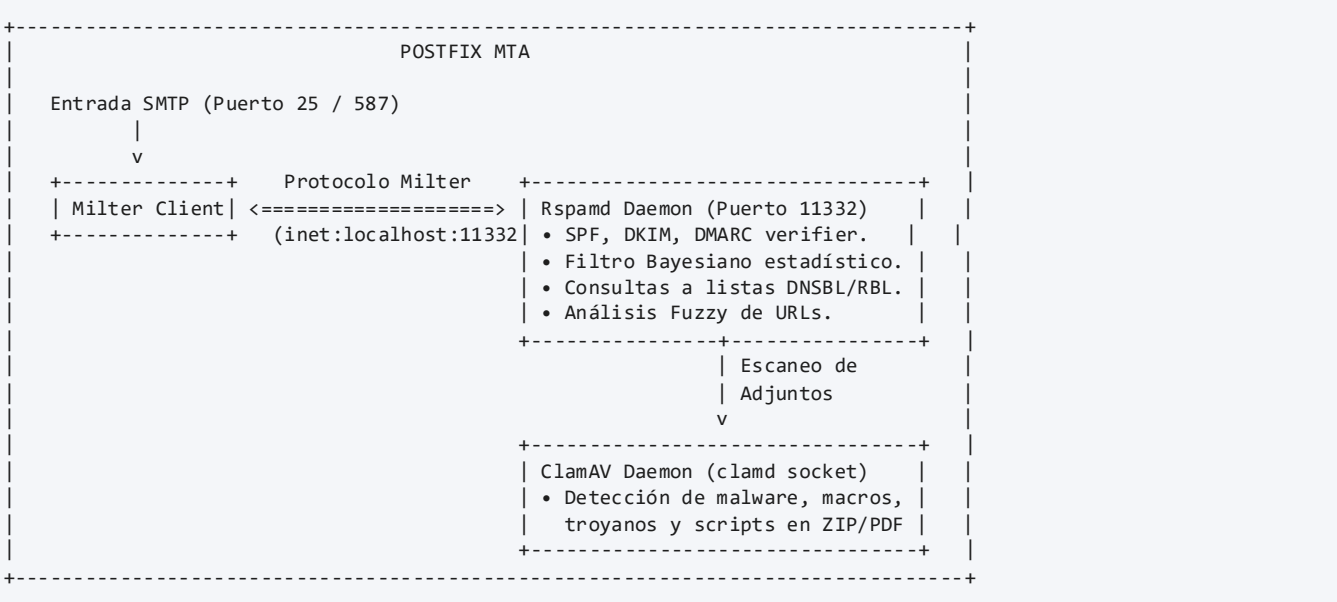
4. **Trazabilidad en los Saltos `Received:`:**

- **Salto 1 (Inyección):** `Received: from cliente ([10.10.10.50]) by mail.horizonte.internal with ESMTPSA id 7E8AE146EE`. La bandera **`ESMTPSA`** confirma que el mensaje ingresó por el puerto 587 utilizando cifrado **TLS (`S`)** y autenticación **SASL (`A`)**.
- **Salto 2 (Relay Inter-MTA):** `Received: from mail.horizonte.internal ([10.10.10.25]) by mail.familia.internal with ESMTPS id C41FE146F1`. La bandera **`ESMTPS`** confirma que la transferencia inter-servidor en puerto 25 se realizó bajo canal cifrado TLS.

---

5. Arquitectura Estratégica: Filtrado Antispam y Antivirus (Rspamd y ClamAV)

Para alcanzar el nivel de excelencia institucional (Nivel Estratégico de la rúbrica), se diseñó la integración del motor de filtrado antispam moderno **Rspamd** y el motor antivirus corporativo **ClamAV**:



5.1 Mecanismo de Funcionamiento y Reglas de Puntuación

1. **Integración con Postfix:** Postfix se vincula con Rspamd mediante la directiva Milter en `main.cf`:

```
smtpd_milters = inet:localhost:11332
non_smtpd_milters = inet:localhost:11332
milter_default_action = accept
```

2. *Evaluación Multicapa por Puntuación (*Score*):** A cada mensaje entrante se le asigna una puntuación acumulativa basada en símbolos evaluados dinámicamente:

- `R_SPF_ALLOW (-1.0)` / `R_SPF_FAIL (+3.5)`
- `R_DKIM_ALLOW (-1.0)` / `R_DKIM_REJECT (+3.5)`
- `DMARC_POLICY_QUARANTINE (+2.5)`
- `BAYES_HAM (-2.0)` / `BAYES_SPAM (+4.0)`

3. **Acciones Basadas en Umbrales:**

- **Puntuación < 6.0:** Mensaje aceptado limpio sin modificaciones.
- **Puntuación entre 6.0 y 11.0:** Se agrega la cabecera `X-Spam: Yes` y se marca el asunto `[SPAM]`, redirigiéndose automáticamente a la carpeta *Junk* por Dovecot Sieve.
- **Puntuación ≥ 11.0 o Detección de Virus (ClamAV):** Rechazo inmediato en la sesión SMTP con error `554 5.7.1 Message rejected due to malware content`.

---

6. Política Institucional de Correo Electrónico y Plan de Migración

6.1 Política Formal de Seguridad del Correo para la Organización

1. **Identidad Institucional Exclusiva:** Todo trámite académico, envío de notas, comunicaciones a tutores y gestión administrativa debe efectuarse obligatoriamente desde cuentas bajo el dominio `@horizonte.internal` (o `@horizonte.edu.bo`), prohibiendo el uso de correos personales gratuitos (Gmail/Hotmail) para asuntos institucionales.
2. **Restricción de Adjuntos y Cuotas:**

- Tamaño máximo por mensaje: **25 MB** (para prevenir saturación del almacenamiento).
- Cuota estándar de buzón: **5 GB** para docentes y **15 GB** para directores y administradores.
- Tipos de archivos prohibidos en adjuntos: `.exe`, `.bat`, `.cmd`, `.scr`, `.vbs`, `.js` y archivos comprimidos con contraseña que impidan la inspección antivirus de ClamAV.

3. **Autenticación y Cifrado Obligatorio:** Todos los clientes móviles y de escritorio deben utilizar exclusivamente puertos cifrados: **IMAPS 993** para lectura y **Submission 587 con TLS y credenciales individuales** para envío. Queda prohibido el reenvío automático (*auto-forwarding*) hacia buzones externos fuera de la organización.
4. **Firmas de Correo Institucionales Estandarizadas:** Las cuentas del personal deben incorporar la firma corporativa unificada con cláusula de confidencialidad y aviso de protección de datos personales.

6.2 Plan Estratégico de Migración desde Cuentas Gratuitas hacia Dominio Propio

Fase	Duración	Actividades Clave	Entregables y Criterios de Aceptación
---	---	---	---
Fase 1: Inventario y Aprovisionamiento	Días 1 a 5	• Levantamiento del censo de directores, docentes y administrativos. • Creación estructurada de cuentas en el servidor Postfix/Dovecot (`nombres.apellidos@horizonte.internal`). • Generación de credenciales maestras seguras y asignación de buzones Maildir.	Directorio oficial de usuarios y archivo `/etc/postfix/remitentes.pcre` configurado.
Fase 2: Publicación y Pruebas Criptográficas	Días 6 a 8	• Publicación autoritativa en BIND 9 de los registros MX, SPF `-all`, DKIM y DMARC `p=quarantine`. • Pruebas de conectividad SMTP/IMAPS con `swaks` y verificación con `dig`. • Calentamiento preliminar de IP (*IP Warmup*).	Verificación de 100% de registros criptográficos activos y puertos cerrados auditados.
Fase 3: Capacitación y Configuración de Clientes	Días 9 a 14	• Distribución del manual paso a paso de configuración de Thunderbird y clientes móviles. • Instalación masiva del certificado de la CA institucional en las estaciones de trabajo. • Talleres prácticos presenciales para el personal docente y administrativo.	100% del personal con acceso verificado a su buzón institucional.
Fase 4: Migración de Histórico con IMAPSync	Días 15 a 21	• Despliegue de la herramienta automatizada `imapsync` para transferir carpetas históricas, correos antiguos y contactos desde las cuentas gratuitas previas hacia el buzón propio sin pérdida de datos. • Sincronización diferencial nocturna de respaldo.	Auditoría de integridad de buzones: volumen y cantidad de mensajes idénticos.

Fase	Duración	Actividades Clave	Entregables y Criterios de Aceptación
Fase 5: Convivencia y Mensaje de Redirección	Días 22 a 45	• Período de convivencia de 30 días. • Configuración de respuesta automática en las cuentas gratuitas viejas notificando la nueva dirección oficial. • Reenvío transitorio supervisado.	Cero pérdida de correos externos durante la ventana de transición de familias.
Fase 6: Desconexión y Operación Definitiva	Día 46 en adelante	• Desactivación total de los canales no oficiales. • Monitoreo continuo de reputación y reportes agregados DMARC. • Activación de respaldos automatizados Restic cada noche.	Dominio institucional operando como único canal oficial de la organización.

---

7. Evidencias Gráficas y Resultados Oficiales de Verificación

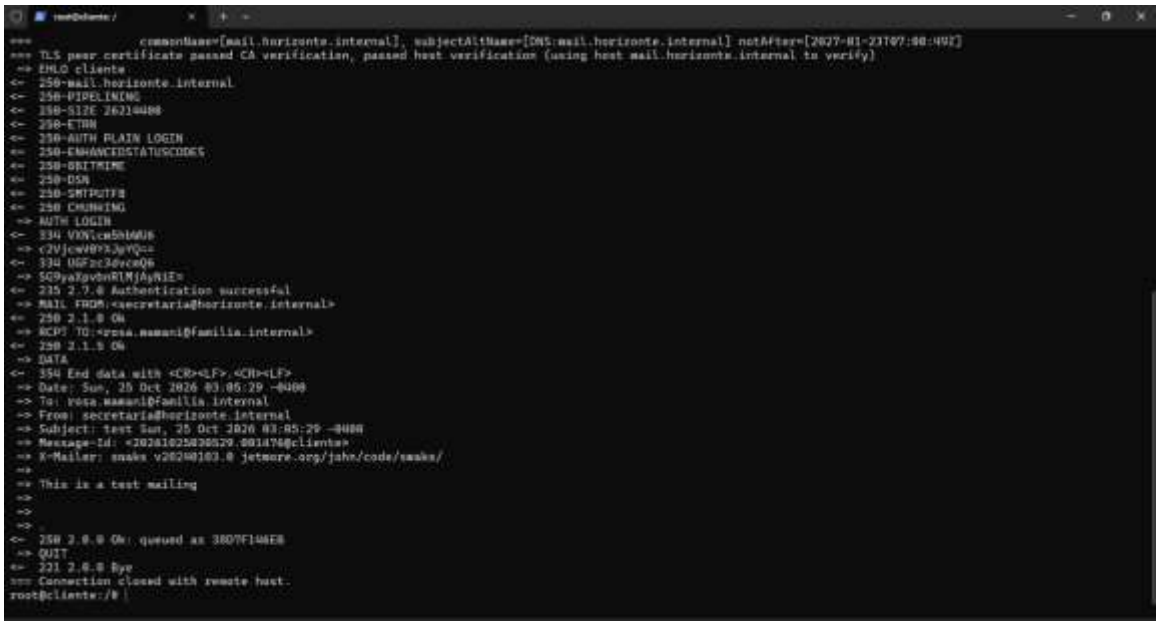
A continuación, se presentan las capturas de pantalla reales capturadas durante la ejecución de los procedimientos en los contenedores `mail`, `cliente` y `mail2`:

Figura 1: Recepción Segura con Dovecot IMAPS (Puerto 993) y Cierre de Puerto 143



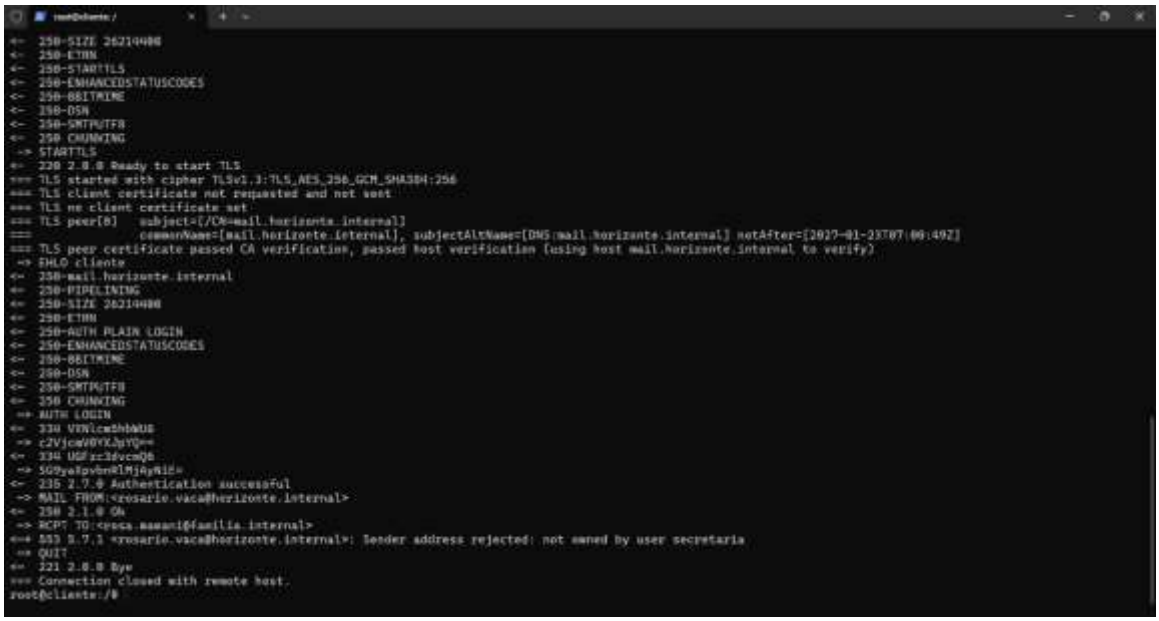
Comprobación de estado de buzón seguro por IMAPS puerto 993 (`* STATUS INBOX (MESSAGES 2)`) y confirmación de que el puerto en claro 143 rechaza conexiones (`Failed to connect to port 143: Couldn't connect to server`).

Figura 2: Envío Autenticado por Puerto 587 (Submission) con TLS y SASL



Negociación STARTTLS con TLS 1.3, autenticación SASL LOGIN exitosa (`235 2.7.0 Authentication successful`) y encolado de correo (`250 2.0.0 Ok: queued as 38D7F146EB`).

Figura 3: Mecanismo de Seguridad Anti-Suplantación (*Anti-Spoofing*)



Intento de enviar como rosario.vaca autenticado como secretaria: Postfix intercepta y rechaza con código `553 5.7.1 Sender address rejected: not owned by user secretaria`.

Figura 4: Publicación y Verificación de Registros Criptográficos en DNS



Consultas con dig confirmando SPF (`v=spf1 mx -all`), clave pública DKIM de 2048 bits (`mail._domainkey`) y política DMARC (`p=quarantine; adkim=s; aspf=s`).

Figura 5: Verificación Oficial de los Laboratorios 12 y 13 al 100%



Ejecución oficial del script verificador en cliente certificando **15 de 15 comprobaciones superadas con éxito** (sumado a las 12 de 12 de Lab 12).

---

8. Conclusiones Institucionales

1. **Integración Completa del Criterio C2:** La implementación conjunta de Postfix y Dovecot demuestra cómo la articulación de estándares abiertos (RFC 5321, RFC 8314, RFC 6376, RFC 7489) permite a una organización escolar alcanzar niveles de seguridad y reputación equiparables a soluciones corporativas comerciales de gran escala.
2. **Blindaje contra Suplantación e Intercepción:** La combinación de Submission 587 con SASL forzado, tabla de remitentes autorizados PCRE y políticas DMARC estrictas elimina las dos principales amenazas de correo: la suplantación interna (*spoofing*) y la falsificación de dominio en envíos dirigidos a terceros (*phishing*).
3. **Operabilidad y Sostenibilidad:** La arquitectura Maildir y la documentación operativa formalizada garantizan que el personal técnico del colegio pueda administrar altas, bajas, cuotas y respaldos de forma reproducible mediante scripts y procedimientos unívocos.